PROJET PERSONNEL 2026 · EN COURS

Détecter le web-skimming avant qu'il frappe

Scanner Magecart et conformité PCI DSS 4.0 pour les pages de paiement e-commerce

Le problème : des scripts tiers non contrôlés sur la page de paiement

1. Compromission

Un script tiers ou inline est modifié : domaine racheté, CDN piraté, CMS vulnérable.

2. Injection

Le code malveillant, souvent obfusqué, s'exécute dans le navigateur du client.

3. Exfiltration

Les données de carte saisies partent vers un domaine contrôlé par l'attaquant.

Les contrôles côté serveur ne voient pas ce qui s'exécute dans le navigateur : c'est le principe du Magecart (web-skimming).

Magecart : famille d'attaques qui volent les données de paiement directement dans le navigateur.

Une menace massive et documentée

2 M+

sites compromis par des attaques Magecart depuis 2015 (DataDome)

100 000+

sites touchés par la compromission de Polyfill.io en 2024 (estimation initiale)

≈ 500 000

clients de British Airways touchés en 2018, sur 15 jours

Sources : DataDome, BleepingComputer, Censys / SecurityAffairs, cside. Estimations publiées par des éditeurs de sécurité.

PCI DSS 4.0 met le navigateur dans le périmètre

Avant la v4.0, la norme protégeait surtout le serveur et les données en transit. Deux nouvelles exigences visent le skimming côté client.

6.4.3 · Inventaire des scripts

Tous les scripts de la page de paiement sont inventoriés, justifiés, autorisés, et leur intégrité est vérifiée.

11.6.1 · Détection d'altération

Un mécanisme alerte en cas de modification des en-têtes HTTP ou du contenu des pages de paiement.

Obligatoires depuis le 31 mars 2025 PCI DSS v4.0.1

Sources : PCI Security Standards Council, documentation éditeurs (Report URI, cside).

Le coût de la non-conformité

4,88 M$

coût moyen mondial d'une violation de données en 2024 (IBM, tous secteurs)

Pénalités contractuelles via les banques acquéreuses (le PCI SSC n'amende pas directement)

Sanctions RGPD en cas de fuite de données personnelles

Perte de confiance des clients, surtout pour les petits e-commerçants

Source : IBM, Cost of a Data Breach 2024. Les pénalités PCI passent par les acquéreurs et les marques de cartes.

Des solutions existent, surtout orientées grands comptes

Acteurs	Type d'offre
Jscrambler, Feroot, Akamai, Imperva, c/side, Source Defense, Reflectiz	Solutions SaaS commerciales
Report URI	Rapports CSP / SRI

Opportunité à valider

Une solution simple et abordable, centrée sur la conformité, pour les PME e-commerce (WooCommerce, Shopify).

Liste non exhaustive. Positionnement PME : hypothèse à vérifier par une étude de marché.

La solution : un plugin qui voit, détecte et prouve

Voir

Inventaire automatique des scripts de la page de paiement, avec empreinte (hash) de chacun.

Détecter

Alerte quand un script change, apparaît, ou qu'une donnée part vers un domaine inconnu.

Prouver

Rapport de conformité 6.4.3 / 11.6.1 exportable pour l'audit.

Objectif final : un plugin installable par un marchand sans équipe sécurité.

MVP v1 : ce qu’il contiendra

1 · Scanner d’inventaire

Playwright charge la page de paiement, liste les scripts externes et inline, calcule un hash SHA-256 de chacun.

2 · Détection d’altération

Comparaison des hashs et des en-têtes HTTP entre deux scans, alerte si un script change ou apparaît.

3 · Règles anti-skimming

Domaines inconnus, code obfusqué (base64, eval, atob), requêtes sortantes suspectes.

4 · Rapport de conformité

Inventaire justifié, historique des changements et preuves horodatées, exportable.

Le MVP est le moteur d'analyse plus une interface minimale dans un plugin WooCommerce.

Fonctionnement : du scan au rapport

Étape 1

Plugin

Le marchand l'installe et indique sa page de paiement.

→

Étape 2

Scan

Le moteur charge la page comme un vrai navigateur.

→

Étape 3

Analyse

Hash, liste blanche et règles anti-skimming.

→

Étape 4

Alerte

Email ou webhook Slack / Discord en cas d'écart.

→

Étape 5

Rapport

Inventaire et preuves de changements, exportable.

Phase suivante : agent JavaScript léger (MutationObserver, PerformanceObserver) pour surveiller la page en temps réel dans le navigateur.

Le scan périodique est la base du MVP. La surveillance en temps réel viendra ensuite.

Exigences PCI DSS couvertes par le MVP

Exigence	Ce que demande la norme	Fonction du MVP
6.4.3	Inventaire, justification, autorisation et intégrité des scripts	Inventaire avec hash, liste blanche et justification par script
11.6.1	Détection et alerte en cas de modification des en-têtes et du contenu	Comparaison entre scans, alerte email ou webhook
Audit	Preuves exploitables par l'auditeur	Rapport exportable et horodaté

Limite assumée : un scan périodique ne remplace pas une surveillance continue. Elle est traitée en phase 2.

Le rapport vise à aider à la conformité, il ne remplace pas l'évaluation d'un auditeur (QSA).

Du plugin à un produit

Modèle (hypothèse)

- Gratuit : inventaire des scripts
- Payant : alertes, rapport de conformité, blocage
- Cible : PME sur WooCommerce puis Shopify
- Prix : [à définir après étude de marché]

Défis à anticiper

- Contournements : iframes cachées, WebRTC
- Performance : aucun ralentissement perceptible du paiement
- Faux positifs : rester utilisable pour un non-expert
- Légal : ne scanner que des sites autorisés

Modèle freemium : hypothèse de travail, à valider avant tout lancement.

Feuille de route

En cours

Cadrage

Exigences PCI DSS, étude des attaques Magecart, architecture.

À venir

Prototype

Scanner Playwright : inventaire des scripts et hash.

À venir

Banc d’essai

Fausse page de paiement avec skimmer inoffensif.

À venir

Plugin et rapport

Interface WooCommerce, alertes, export du rapport.

Résultat attendu : détecter les cas de web-skimming avant exploitation et produire un rapport de conformité exploitable.